

> MODULE_03 // CYBERSECURITY

Network and Computer Attacks

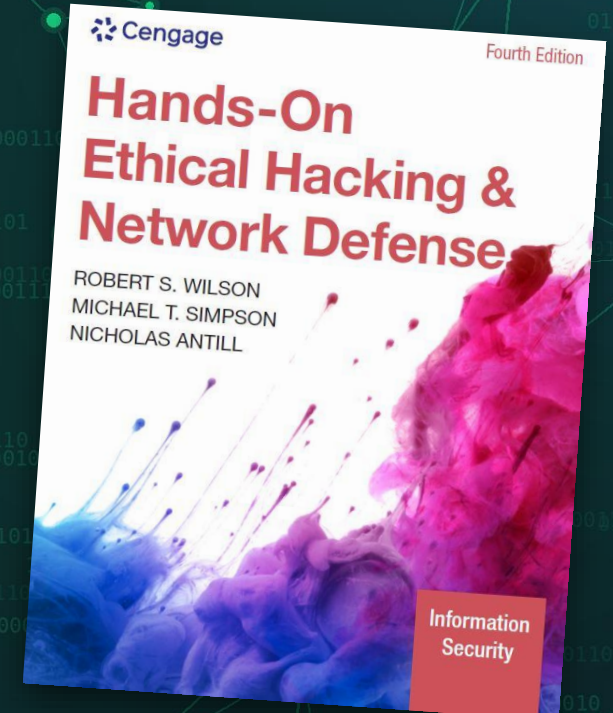
Hands-On Ethical Hacking and Network Defense, 4th Edition

MALWARE

DEFENSE

NETWORK ATTACKS

PHYSICAL SECURITY



Module Objectives

By the end of this module, you should be able to:

01



Describe the different types of malicious software and what damage they can do

02



Describe methods of protecting against malware attacks

03



Describe the types of network attacks

04



Identify physical security attacks and vulnerabilities

01

Malicious Software

Viruses, worms, Trojans, spyware and adware: how they spread and what they do.



Malicious Software (Malware)

- Network attacks are initiated to steal data that can be used or sold for financial gain, or to carry out a sociopolitical agenda
- Malware was once targeted specifically at Windows, Linux, and other traditional OSs
 - Now, it is written to target tablets, smartphones, and other Internet-connected devices



Virus



Worm



Trojan program

MAIN GOAL



To make money

ATTACK SURFACE HAS GROWN



PCs & servers



Phones & tablets



IoT devices

Viruses: How They Work



Virus: A program that attaches itself to a file or another program, often sent via email. It can't replicate itself or operate without the presence of a host; it does not stand on its own.



Phishing

The sender of a phishing email uses social engineering to lure a user into following a malicious link to a fake website



Ransomware

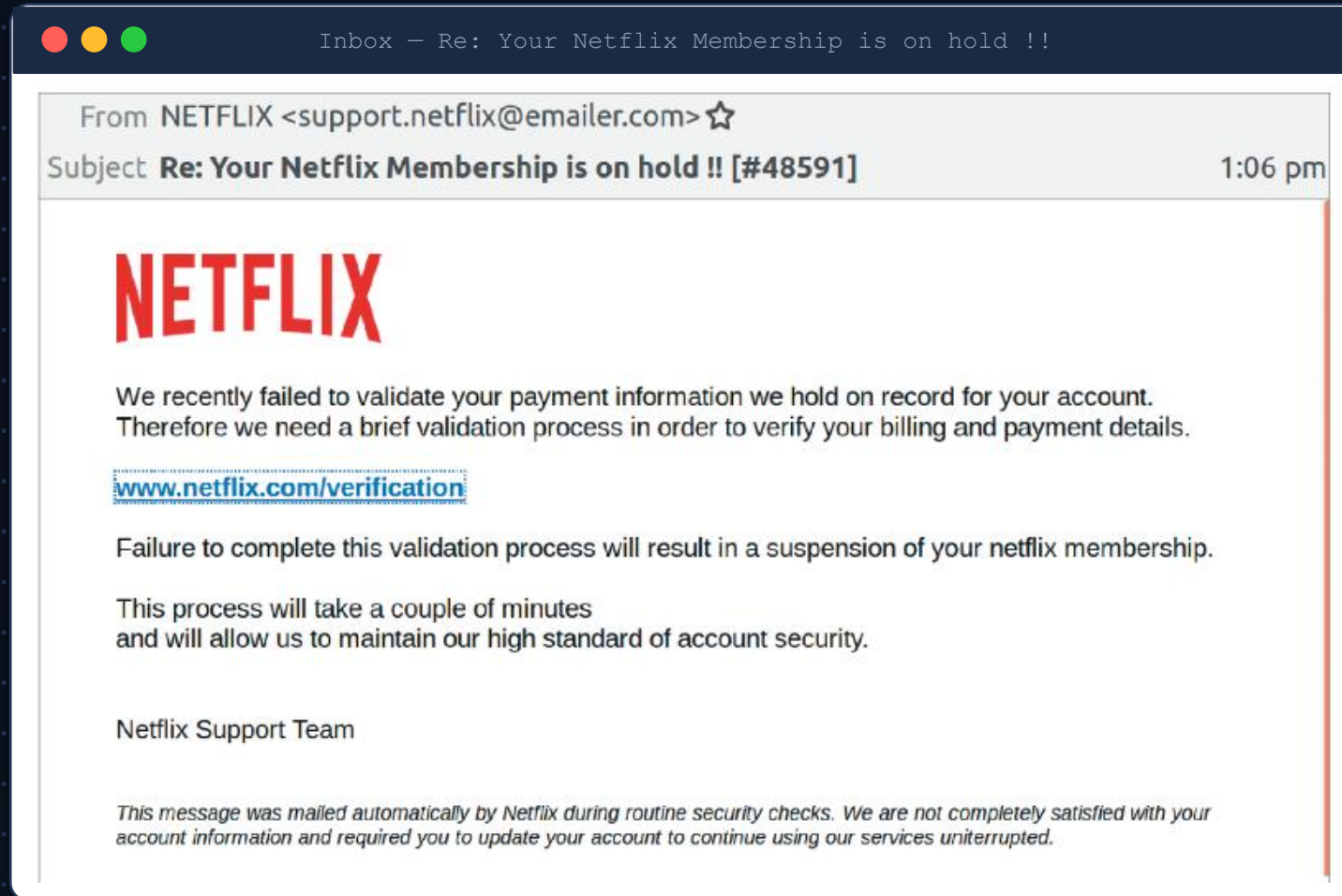
A type of virus that locks a target system until a ransom is paid

*EXAMPLES



Bad news about viruses: there is no foolproof prevention method.

Spot the Phish



RED FLAGS

- 1 Spoofed sender**
Display name says NETFLIX, but the address is @emailer.com
- 2 Manufactured urgency**
“on hold !!” and threat of membership suspension
- 3 Suspicious link**
Link text looks legitimate; the real destination can differ. Hover before clicking
- 4 Credential bait**
Asks you to “verify your billing and payment details”

Figure 3-1 Phishing email message

Defending Against Viruses

LAYER 1



Antivirus software

- Compares signatures and common malicious behaviors of known viruses against every file on a computer
- Signatures are kept in a virus signature file
 - Must update regularly
 - Many packages offer automatic updates

LAYER 2



Network security devices

- Can monitor entire networks
- Intercept malware before it reaches users

LAYER 3



Sandboxing

- Run programs in a secure, isolated operating area
- Prevents malicious files from being written to the hard drive

Common Computer Viruses (1 of 3)



Ryuk

RANSOMWARE

peak: 2020

- Behind more than one-third of all ransomware attacks in 2020
- Targets companies, hospitals, and government municipalities
- Encrypts critical files; typically demands a multimillion-dollar ransom



FormBook

INFOSTEALER

MaaS

- Data stealer and form grabber: steals clipboard contents, logs keystrokes, steals data while you browse
- Sold as “malware-as-a-service” on hacking forums by subscription
- Usually spread via spam email with malicious attachments



CryptoLocker

RANSOMWARE

250K+ PCs (2016)

- Considered the father of many ransomware viruses; now a name for a family
- Locks files in an encrypted container and demands ransom for decryption
- Delivered by email lures; victims get a set time to pay

Common Computer Viruses (2 of 3)



MalumPOS

POS MALWARE

mid-2015

- Attacked point-of-sale (POS) devices at hotel chains
- Finds, intercepts, copies, and exfiltrates payment card data from the magnetic strip
- POS attacks were rare in 2020; a new strain targets personally identifying information only



Carbanak

FINANCIAL

phishing

- Phishing emails targeting financial institutions: a Word document plus a malicious .cpl file (remember this for the base-64 exercise)
- Checks it can gain proper privileges, then opens a backdoor to remote servers
- Used for fraudulent transactions in funds-transfer systems and ATMs

Common Computer Viruses (3 of 3)



Gumblar

WEB MALWARE

Mar 2009 · back in 2020

- Mass-hacked hundreds of thousands of websites, then exploited visitors' browsers via Adobe PDF and Flash flaws
- 2020 resurgence hit WordPress, Drupal, Joomla and other PHP sites
- Steals FTP credentials, hijacks Google searches, blocks antivirus update sites; new variants add a botnet backdoor



Gpcode / PGPCode

RANSOMWARE

2008 · active 2020

- Not widespread, but unique
- Uses practically unbreakable 1024-bit asymmetric key encryption to hide a user's documents
- Holds files for ransom until the victim pays for the encryption key

Decoding Suspicious Attachments

- Some viruses contained in email attachments were encoded in base 64
- Running a base-64 decoder on suspicious attachments can help determine whether malware is present

What to look for

- Hidden computer programs
- Executable pieces of programming code known as shell
 - Creates an interface to an OS for issuing system commands
 - Should not appear in an email attachment

```
analyst@lab: ~/quarantine

$ cat invoice_attachment.txt
TVqQAAMAAAAEAAAA//8AALgAAAAAAAAAQAAAAAAAA...
$ base64 -d invoice_attachment.txt | head -c 80
MZ.....
!This program cannot be run in DOS mode.

# "MZ" header = Windows executable
# hidden inside an "invoice". Red flag!
```

Illustrative output. Decode samples only inside an isolated lab VM.

Macro Viruses

- **Macro virus: a virus coded as a macro in programs that support a macro language (e.g., Visual Basic for Applications)**
 - Macro: basically, a list of commands
 - Can be coded to carry out several malicious actions
- **Viruses were created by programmers in the past**
 - Today, even nonprogrammers can create viruses easily
 - Step-by-step instructions are posted on websites

1999

Melissa appears



Security professionals
learn from thinking like
attackers



Invoice.docm — VBA editor



What analysts look for in a document macro:

```
Sub AutoOpen()  
    ' runs the moment the file opens  
    Set o = CreateObject(...)  
    ' fetches a remote payload  
    Shell <hidden command>  
    ' executes it silently  
End Sub
```

AutoOpen

CreateObject

Shell

= indicators

Worms

Worm: a program that replicates and propagates itself without having to attach itself to a host

INFAMOUS EXAMPLES

Stuxnet

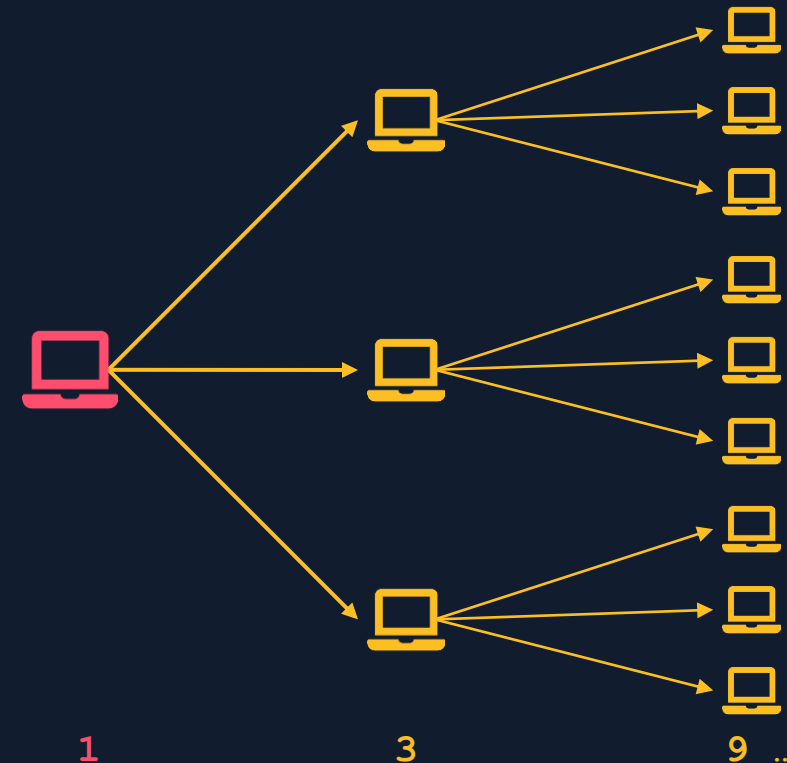
Code Red

Conficker

Costing businesses billions

- Lost productivity from downtime and time spent recovering lost data
- Reinstalling programs and operating systems
- Hiring or contracting IT personnel

SELF-REPLICATION



In theory, a worm could infect every computer in the world over a short period

A Decade and a Half of Infamous Worms

2003

Slammer

Shut down 13,000+ ATMs of a major U.S. bank

2008

Conficker

Spread via a Microsoft network service flaw

2011

Duqu

Stuxnet-like design built to steal data

2017

WannaCry

230,000+ PCs in ~150 countries in one day

2007

Storm

Botnet worm infected millions of systems

2010

Stuxnet

Sabotaged Iranian uranium centrifuges

2012

Flame

Mic, webcam, keystroke and screen spying

Dates as given in the textbook tables that follow.

Common Computer Worms (1 of 2)



WannaCry

CRYPTOWORM

2017

- Ransomware cryptoworm exploiting Windows SMB file-sharing flaws to spread system to system
- Then releases its ransomware attack
- 230,000+ computers in ~150 countries within a day



Flame (KyWiper)

ESPIONAGE

May 2012

- Often touted as the most complex malware ever created
- Infected local and remote computers with advanced techniques
- Microphone/webcam spying, keystroke logging, screen capture



Stuxnet

ICS SABOTAGE

2010

- Found on industrial control systems at an Iranian nuclear facility; believed delivered via USB drive
- Took control of uranium refinement equipment: centrifuges spun erratically, then failed
- Like spinning a washing machine until the motor burns out

Common Computer Worms (2 of 2)



Duqu

DATA THEFT

Oct 2011

- Stuxnet-like design, but its goal was stealing data
- Targeted government agencies in Europe and the Middle East



Storm

BOTNET

Jan 2007

- Spread via automatically generated email messages
- Botnet Trojan and variants infected millions of systems



Waledac

EMAIL WORM

remote-controlled

- Harvests and forwards passwords; spreads as eCard.exe
- A variant used geo-IP lookup to fake a local Reuters “dirty bomb” story



Conficker

BOTNET WORM

late 2008

- Spread using a Microsoft network service vulnerability; updates itself dynamically
- Detectable remotely with Nmap plus a Conficker signature plug-in



Slammer

DATABASE WORM

2003

- Infected database servers on the same network
- Purported to have shut down 13,000+ ATMs of one of the largest U.S. banks

Worms in the Real World



► Wana Decrypt0r (WannaCry Ransomware)

Computerphile · Dr Mike Pound



► Stuxnet: Computer Worm Opens New Era of Warfare

CBS 60 Minutes

Discuss: Which single defensive control would have most limited each worm's spread?